Risk Analysis of MFA Bypass in Cloud IAM Systems

Tariqul Islam ID:40268283, tariqulislam2594@gmail.com
Ehsan Karim ID: 25296358 Ehsan.karim1088@outlook

Dataset: https://github.com/towkictg/INSE6320-Project

Abstract— This study assesses the risks of Multi-Factor Authentication (MFA) bypass within Cloud systems. Using recent incident trends and a synthetic dataset, we apply a set of risk analysis methods, including Poisson distribution, Fault Tree Analysis (FTA), F-N curves, Survivability Analysis (K-M Estimate), and Bayesian Network Analysis. The study also uses Decision Tree and Payoff Table Analysis, Decision Making using EV and EVPI, and Sensitivity Analysis to evaluate security strategies ranging from legacy SMS/Push to phishing-resistant standards. The goal is to measure the risk of MFA failure and provide a clear framework for evaluating the financial and organizational impact of these breaches.

Keywords— MFA Bypass, Risk Analysis, Cloud IAM, Fault Tree, Bayesian Network.

I. INTRODUCTION

Cloud systems rely on Identity and Access Management (IAM) as their main security barrier. While MFA is critical, it remains vulnerable to multiple bypass methods such as transparent proxies, session interception, and SIM swapping [2][5]. This study looks at the difference between theoretical safety and actual failure in real situations. The aim of this project is to use math and risk models to see how likely an MFA failure is and what the impact would be.

Our methodology starts by Identifying Risks and moves into a Quantitative Risk Analysis. This includes Poisson distribution, Fault Tree Analysis, and Bayesian Networks. Finally, we perform a Decision Analysis to compare different authentication strategies. By calculating Expected Value (EV) and EVPI, we determine which approach produces the lowest expected annual loss for an organization facing modern threats.

II. LITERATURE REVIEW

Research shows that attackers have moved from stealing passwords to attacking the actual login process itself [1]. While traditional MFA reduces risk compared to simple passwords, it is still vulnerable to replay attacks, social engineering, and technical flaws in MFA handling pages [5]. Even though some reports claim high safety rates [6], data from 2024-2025 shows that many successful breaches occur even when MFA is active [5]. This justifies the use of Sensitivity Analysis and Cost-Benefit Analysis to evaluate the transition toward phishing-resistant authentication methods [1].

III. PROBLEM DESCRIPTION

Relying on legacy MFA methods like SMS or push notifications presents a core resilience challenge. There is a clear conflict between the high safety rates reported by providers and the high number of bypasses seen in real-world attacks [5][6]. This study analyzes the system by examining three main components: the login service, the user, and the login session token.

Since private company data is not available, this study uses a synthetic dataset simulating 1,000 login events. This data allows us to apply quantitative methods to find a Decision Justification for different security strategies. We evaluate the Expected Annual Loss by comparing weak, phishable MFA against stronger, hardware-bound alternatives. The analysis focuses on how various attack vectors, such as MITM and token theft, influence the Risk Reduction Achieved across different implementation tiers.

IV. RISK ASSESSMENT

A. Identifying Risks

Threats:

- AiTM/Session Interception: Real-time theft of credentials and session tokens [1], [5].
- MFA Fatigue/Push Bombing: Exploiting user exhaustion to induce fraudulent approvals [2], [5].
- SIM Swapping: Interception of SMS-based codes via hijacked mobile numbers [6].
- Token Theft: Direct compromise of authenticated cookies to bypass prompts [5].

Vulnerabilities:

- Legacy Protocol Support: Systems allowing IMAP/SMTP that bypass MFA enforcement [5].
- Non-Phishing-Resistant MFA: Reliance on SMS or standard push without origin-binding [1], [6].
- Human Reliability: Susceptibility to social engineering and notification exhaustion [5].

Assets at Risk:

- Cloud Infrastructure: Global admin identities, M365 tenants, and user directories [5].
- Financial Capital: Mean economic loss of $4.45M per Business Email Compromise (BEC) event [7].
- Reputational Integrity: F-N curve modeling showing a mean account compromise rate of 79% [5].

B. Quantitative Risk Analysis

Quantitative models were used to determine the probability and impact of MFA-related failures. Details of the modeling approaches and results are elaborated in Section V:

- Poisson distribution (estimation of bypass attack frequency).
- Fault Tree Analysis (authentication failure logic).
- F-N curve (compromise frequency vs. severity).
- Survivability Analysis using K-M Estimate.
- Bayesian Network Analysis.
- Decision Tree and Payoff Table Analysis.
- Decision Making using EV and EVPI Approach.
- Decision Making with Conditional Probabilities and Efficiency.
- Sensitivity Analysis

C. Risk Response Strategies

Avoid:

- Protocol Deactivation: Disabling legacy protocols (IMAP/SMTP) to eliminate the risk of MFA-bypass through older mail clients.
- SMS Factor Removal: Eliminating SMS-based authentication for high-privilege accounts to avoid interception and SIM-swapping risks.

Mitigate:

- FIDO2 Security Keys: Deploying hardware keys to 1,000 employees. The current market average cost for a professional-grade security key is $50/unit.
- Number Matching: Enabling "Match" prompts to prevent MFA fatigue and accidental approvals.
- Session Management: Enforcing shorter token lifetimes to limit the window of opportunity for stolen cookies.

Transfer:

- Cyber Insurance: Purchasing a policy to offset the average $4.45M financial impact of a data breach. Standard annual premiums for this coverage are estimated at $10,000 - $15,000 for mid-sized firms.

Retain:

- Residual Risk: 5% (determined by the results of the Bayesian Network and Decision Tree analysis in Section V).

D. Control Measures Implemented

Cost of Controls:

- Upfront Investment ($50,000): Calculated as 1,000 employees and $50/unit hardware cost for phishing-resistant security keys [8].

$$\text{Upfront Investment} = 1{,}000 \times 50 = \$50{,}000$$

- Annual Recurring Cost ($17,000): Includes estimated cyber insurance premiums [9] and system maintenance.

Risk Reduction Achieved:

• Bypass Success Probability:

The baseline breach probability p = 0.056 (5.6%) comes from Section V-A (Poisson/Breach Frequency Analysis) based on 56 successful compromises in 1,000 authentication attempts.

From Section IV (Fault Tree Analysis), FIDO2 removes major phishing and AiTM attack paths, leaving only 5% residual risk.

• Overall System Failure Reduction:

$0.056 \times 0.05 = 0.0028$

The resulting system failure probability becomes 0.28% after FIDO2 deployment, showing significant reduction in IAM compromise risk.

V. RISK ANALYSIS

A. Poisson Distribution

Below is a tabular representation of the data for total number of MFA breach only (Not total number of breach) between the year 2021 – 2025 from our simulated data.

Year Range	Total Incidents	Total Years	Incidents per Year (λ)
2021–2025	8	5	1.6

A total of 8 successful MFA bypass incidents were observed over 5 years, resulting in an average annual rate:

$$\lambda = \frac{8}{5} = 1.6$$

Table 1: Poisson Probability Table for Annual Breach

Time Frame	λ	P (X ≥ 1)	Relevance to Cloud IAM Risk Analysis
1 Year	1.6	79.81%	High likelihood of at least one MFA bypass annually.
2 Years	3.2	95.92%	Significant cumulative risk requiring stronger controls.
5 Years	8	99.97%	Long-term exposure makes bypass incidents nearly certain.
10 Years	16	~100%	Continuous investment in phishing-resistant MFA is essential

Table 2: Relevance Of Poisson Results to MFA Bypass Risk Analysis

Poisson Result	Security Implication	Required Action
79.81% (1 year)	Likely annual MFA bypass	Strengthen authentication factors
95.92% (2 years)	High compromise probability	Deploy phishing-resistant MFA
99.97% (5 years)	Long-term exposure	Implement Zero Trust monitoring
~100% (10 years)	Breach almost inevitable	Maintain incident response readiness

This data underscores the need for proactive security engineering and identity resilience in Cloud IAM systems. The Poisson analysis shows a nearly certain probability (99.97%) of at least one successful MFA bypass within a 5-year span, directly informing the organization's urgent requirement for phishing-resistant standards. These results justify the transition from legacy SMS/Push to FIDO2 hardware and Zero Trust monitoring, making a strong case for high-tier security investment. Consequently, probabilistic modeling is critical for quantifying identity risk and optimizing infrastructure resilience against modern authentication threats

B. Fault Tree Analysis

A fault tree analysis identifies how individual component failures or attack steps combine to produce a system-level failure. In this study, the top event represents a successful MFA bypass in a cloud IAM system. Four intermediate attack paths were modeled: Adversary-in-the-Middle (AITM) attacks, MFA fatigue attacks, SIM swap attacks, and session token theft.

Each intermediate event is triggered by multiple base events connected through AND gates, meaning that all underlying conditions must occur for the attack to succeed. The intermediate events are then connected to the top event through an OR gate, indicating that a successful MFA bypass can occur if any attack path succeeds.

Table 3: Justification for simulated probabilities assigned to fault tree primary events

Primary Event	Simulated Probability	Reasoning Evidence
Phishing Link Delivered	60%	Phishing remains one of the most common initial attack vectors in identity-based attacks.
Password Theft	50%	Credential theft occurs through phishing, malware, or reused passwords across services.
MFA Code Interception	40%	Real-time phishing proxies and adversary-in-the-middle kits can capture MFA codes.
Repeated MFA Push Requests	35%	MFA fatigue attacks rely on repeated push notifications until the user approves one.
Personal Information Theft	45%	Personal data required for SIM swap attacks is often available from data breaches or social engineering.
SMS OTP Interception	30%	Once a SIM swap occurs, attackers can intercept SMS authentication codes.
Session Token Extraction	40%	Malware or malicious websites may extract browser session tokens.

Table 4: Intermediate Event Probability Calculations

Intermediate Event	Calculation and Result
AITM Attack (Phishing + Password Theft + MFA Code Interception)	P = 0.60 × 0.50 × 0.40 = 0.12
MFA Fatigue Attack (Password Theft + Repeated MFA Requests)	P = 0.50 × 0.35 = 0.175
SIM Swap Attack (Personal Information Theft + SMS OTP Interception)	P = 0.45 × 0.30 = 0.135
Token Theft (Phishing Link + Session Token Extraction)	P = 0.60 × 0.40 = 0.24

Top Event Calculation

The probability of a successful MFA bypass is calculated using the OR gate formula applied to the four intermediate events.

$$P(\text{Top Event}) = 1 - \prod_{j=1}^{4}(1 - P_j)$$
$$= 1 - (1 - 0.12)(1 - 0.175)(1 - 0.135)(1 - 0.24)$$
$$= 1 - (0.88 \times 0.825 \times 0.865 \times 0.76)$$
$$= 1 - 0.477$$
$$= 0.523$$

Top Event Probability = 0.523 (52.3%)

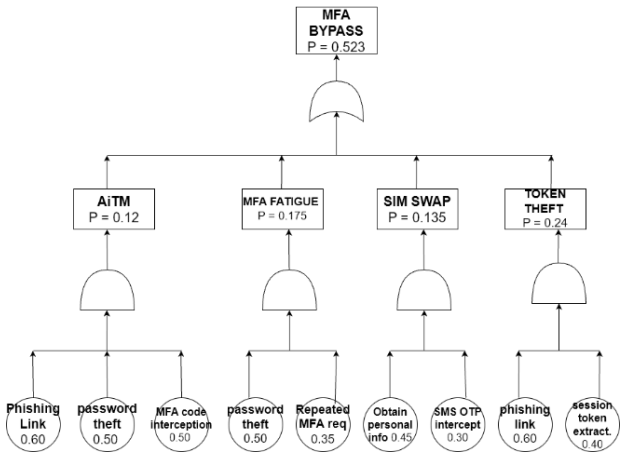

Fig.1: Fault Tree diagram

The calculated probability of 52.3% indicates that, under simulated conditions, there is a significant likelihood that at least one MFA bypass technique may succeed in a cloud IAM system. Among the modeled attack paths, token theft and MFA fatigue attacks contribute notably to the overall risk, emphasizing the importance of phishing-resistant authentication mechanisms, secure session management, and continuous monitoring of authentication activity.

C. F-N Curve Analysis

The F–N curve is commonly used in risk analysis to illustrate the relationship between the magnitude of an adverse event and its cumulative frequency of occurrence. In this study, the F–N curve represents the distribution of financial losses resulting from MFA bypass incidents within the simulated enterprise environment.
The financial losses were ranked from highest to lowest, and the cumulative frequency F was calculated using:

$$F = \frac{i}{T}$$

Where,
i = rank of the event
T = total years

Table 5: Annual Frequency of MFA Events by Loss (USD)

Rank (i)	User ID	Financial Loss (N)	Calculation (i/5)	Cumulative Frequency (F)
1	14	$248,124.90	1 / 5	0.2
2	405	$211,996.59	2 / 5	0.4
3	789	$210,000.00	3 / 5	0.6
4	502	$198,000.00	4 / 5	0.8
5	890	$175,000.00	5 / 5	1.0
6	112	$156,000.00	6 / 5	1.2
7	10	$134,387.25	7 / 5	1.4
8	256	$42,000.00	8 / 5	1.6

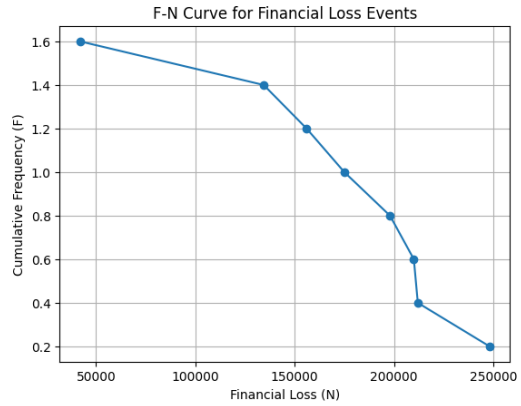

Fig.2: F-N Curve

D. Kaplan–Meier Survival Analysis

The Kaplan–Meier (KM) estimator provides a non-parametric estimate of the probability that a financial loss exceeds a given threshold. In the context of this analysis, the Kaplan–Meier method is used to evaluate the survival probability of financial losses associated with MFA bypass incidents.
The Kaplan–Meier survival function is defined as:

$$S(t) = \prod \left(1 - \frac{d_i}{n_i}\right)$$

where, di = number of events occurring at step i
ni = number of remaining observations before the event.

Table 6: Kaplan–Meier Survival Estimates Calculation

Rank	Financial Loss (N)	Remaining Observations (n_i)	Events (d_i)	Survival Probability S(t)
1	248,124.90	8	1	0.875
2	211,996.59	7	1	0.750
3	210,000.00	6	1	0.625
4	198,000.00	5	1	0.500
5	175,000.00	4	1	0.375
6	156,000.00	3	1	0.250
7	134,387.25	2	1	0.125
8	42,000.00	1	1	0

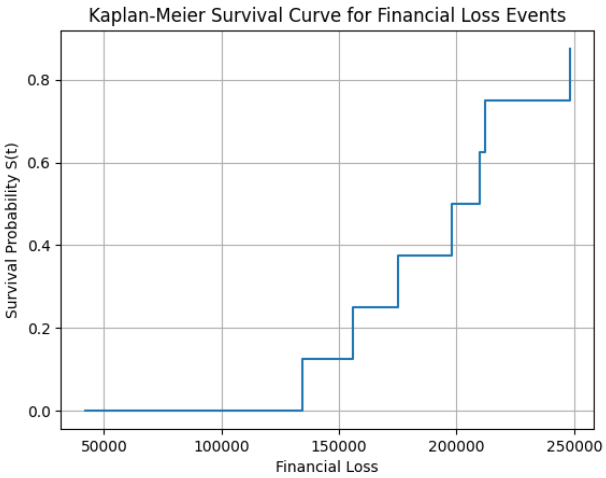

Fig.3: Kaplan–Meier Survival Curve

E. Bayesian Network Analysis

The Bayesian Network (BN) serves as the primary integration tool for this project. It mathematically links the threat frequencies identified in the dataset used for this project with the logical vulnerabilities calculated in the Fault Tree Analysis (FTA). By representing these dependencies in a Directed Acyclic Graph (DAG), we simulate how specific attack vectors interact with security controls to produce financial outcomes.

1) Nodes and States

The network is constructed using four variables grounded in empirical and logical data:

- Attack Vector (A): Threat arrival probabilities from the dataset: Phishing (23.3%), SIM Swap (25.2%), AiTM Proxy (26.2%), Token Theft (25.1%).
- MFA Control (C): Defensive distribution from the dataset: NO_MFA (5%), SMS (65%), TOTP (30%).
- Bypass Success (B): Binary state (Yes/No) representing MFA failure, with probabilities imported from FTA results.
- Economic Outcome (E): Binary state (Stable/Loss) conditional on Bypass Success and Incident Response Speed.

2) Conditional Probability Tables (CPTs)

Table 7: CPT For Bypass Success (B)
Conditional on Attack Vector (A) and MFA Control (C)

Attack Vector (A)	MFA Control (C)	P (B=No)	P (B=Yes)	Source / Logic Calculation
Phishing	NO_MFA	0.05	0.95	Dataset Inference: 95% failure without MFA.
Phishing	SMS	0.82	0.18	FTA Result: 0.60 (Link) × 0.30 (Intercept).
Phishing	TOTP	0.76	0.24	FTA Result: 0.60 (Link) × 0.40 (Intercept).
SIM Swap	SMS	0.865	0.135	FTA Result: SIM Swap Intermediate Event.
AiTM Proxy	TOTP	0.76	0.24	FTA Result: AiTM Intermediate Event.
Token Theft	TOTP	0.76	0.24	FTA Result: Token Theft Intermediate Event.

Table 8: CPT For Economic Outcome (E) Conditional on Bypass Success (B) And Incident Response Speed (M)

Bypass Success (B)	Response Speed (M)	P(E=Stable)	P (E=Loss)	Source / Logic Calculation
No	Any	1.00	0.00	Baseline: No breach leads to zero MFA loss.
Yes	Strong (Auto)	0.40	0.60	Heuristic: Auto-revocation stops 40% of damage.
Yes	Moderate (Alerts)	0.15	0.85	Heuristic: Alerts enable mitigation in 15% of cases.
Yes	Weak (Manual)	0.01	0.99	Dataset Inference: Observed breaches with slow response.

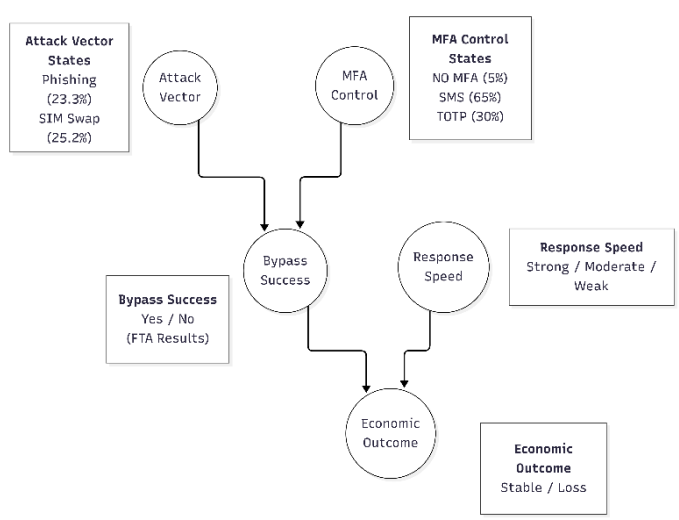

Fig. 4. Bayesian Network for MFA Bypass

3) Integrated Risk Calculation (Scenario Analysis)

To demonstrate the model's precision, we calculate the total probability of loss for a high-prevalence profile in the dataset.

Scenario: A TOTP user (30% prevalence) targeted by an AiTM Proxy attack (26.2% prevalence) with Moderate Incident Response.

- Bypass Vulnerability: P(B = Yes | A, TOTP) = 0.24 (from FTA)
- Impact Probability: P(E = Loss | B, Moderate) = 0.85 (from Response Heuristic)

Total Integrated Risk Calculation:

$$P(\text{Loss Outcome}) = 0.24 \times 0.85 = 0.204$$

$$= (20.4\%)$$

Interpretation:
For every 100 AiTM attacks on TOTP users under moderate monitoring, 20.4 result in financial loss. This explains the frequency of successful breaches reported in the Poisson Distribution (Section V-A).

4) Strategic Conclusion

The Bayesian analysis shows that risk is a product of both frequency and logic:

- Token Theft and AiTM Proxy attacks are nearly twice as likely to succeed against TOTP as SIM Swap.
- Moderate response (85% loss probability) confirms that human-led alerting is insufficient to prevent financial damage.
- This justifies the adoption of Strong Automated Revocation and FIDO2 MFA for improved resilience.

F. Decision Tree and Payoff Table Analysis

This section evaluates the financial implications of MFA investment strategies by mapping the cost of security controls against the Residual Risk (remaining exposure) after those controls are applied.

1) Payoff Table Overview

The payoff table summarizes the net financial outcome for each decision. The States of Nature represent whether an attack is Stable (Blocked) or results in a Breach (Successful).

Table 9: Payoff Table (Net Outcome in USD)

Decision Alternative	Attack Blocked (Stable)	Attack Successful (Breach)	Risk Logic / Calculation
No Control	$0	-$248,000	100% Risk: Full exposure to max dataset loss.
Monitoring (SIEM)	-$25,000	-$173,800	60% Residual Risk: $-25{,}000 + (0.60 \times -248{,}000)$
FIDO2 (Physical Keys)	-$50,000	-$62,400	5% Residual Risk: $-50{,}000 + (0.05 \times -248{,}000)$

2) Justification of Payoff Values

- No Control: Baseline state with no upfront investment; organization liable for the full $248,000 impact.
- Monitoring (SIEM): $25,000 investment in detection infrastructure; reduces impact by 40% (60% residual risk) based on Response Heuristic.
- FIDO2 (Physical Keys): $50,000 investment for physical keys for 1,000 employees; neutralizes technical bypasses like AiTM and Token Theft, 5% residual risk remains for non-technical threats.

3) Decision Criteria and Calculations

3.1. Optimistic (Maximax) Criterion

- Logic: Assumes the best-case "Stable" state; selects maximum payoff.
- Results: No Control (0), Monitoring (-$25k), FIDO2 (-$50k)
- Decision: No Control

3.2. Conservative (Maximin) Criterion

- Logic: Assumes the worst-case "Breach" state; selects least negative outcome.
- Results: No Control (-$248k), Monitoring (-$173.8k), FIDO2 (-$62.4k)
- Decision: FIDO2 (Physical Keys)

3.3. Minimax Regret Criterion

- Logic: Minimizes maximum opportunity cost (regret) of not choosing the optimal strategy.

Table 10: Regret Table (Usd)

Decision Alternative	Attack Blocked (Regret)	Attack Successful (Regret)	Max Regret
No Control	$0	$185,600	$185,600
Monitoring (SIEM)	$25,000	$111,400	$111,400
FIDO2 (Physical Keys)	$50,000	$0	$50,000

Decision: FIDO2 (Physical Keys) minimizes maximum regret at $50,000.

4) Decision Tree Visualization

The decision tree maps these choices against the probability of breach (P) and probability of stable outcome (1-P), where P is the likelihood of a successful bypass as modeled in the Bayesian Analysis.

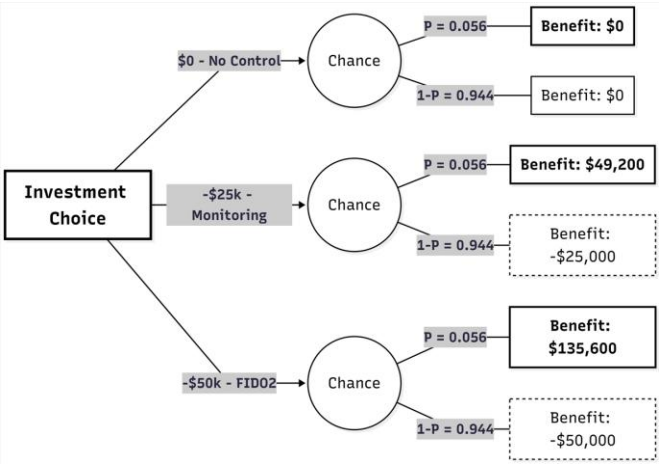

Fig. 5. Decision Tree Model Evaluating MFA Investment Options

5) Strategic Conclusion

The analysis confirms that while No Control is the optimistic choice, it carries a massive "Regret" potential of $185,600. Both the Conservative and Minimax Regret models favor FIDO2, as it provides the most stable financial "floor" by reducing total risk exposure to just 5%.

G. Decision Making with Probabilities: Expected Value and EVPI

This section evaluates investment alternatives using Expected Value (EV) based on empirical breach rates from the used dataset.

1) Assigned Probabilities

- Stable (94.4%): 944 incidents where attacks were successfully blocked.
- Breach (5.6%): 56 successful compromises (48 No-MFA + 8 technical MFA bypasses).

2) Mathematical Formulas

$$EV = \sum P_i \times V_i$$

$$EVwPI = \sum P_i \times \text{Best Payoff in State } i$$

$$EVPI = |EV_{wPI} - EV_{best}|$$

3) Expected Value Calculation

Table 11: Expected Value Per Decision

Alternative	Stable (0.944)	Breach (0.056)	EV Formula	EV (USD)
No Control	$0	-$248,000	(0 × 0.944) + (-248k × 0.056)	$= -13{,}888$
Monitoring (SIEM)	-$25,000	-$173,800	$EV_{Monitoring} = (0.944 \times -25{,}000) + (0.056 \times -173{,}800)$	$= -33{,}333$
FIDO2 (Physical Keys)	-$50,000	-$62,400	$EV_{FIDO2} = (0.944 \times -50{,}000) + (0.056 \times -62{,}400)$	$= -50{,}694$

4) Expected Value (EV) Decision

Decision: No Control yields the highest EV (-$13,888). Statistically, the low breach frequency 5.6% in the dataset makes the high upfront costs of SIEM or FIDO2 exceed the average yearly loss.

5) Expected Value of Perfect Information (EVPI)

$$EVwPI = (0.944 \times 0) + (0.056 \times -62{,}400) = -3{,}494.40$$

$$EVPI = |-3{,}494.40 - (-13{,}888)| = 10{,}393.60$$

6) Interpretation and Recommendation

While the EV favors No Control due to low breach frequency, it fails to account for the $248,000 catastrophic loss potential. When balanced with Minimax Regret (Section F), FIDO2 (Physical Keys) remains the recommended choice to cap maximum liability. The EVPI of $10,393.60 represents the maximum justifiable spend on predictive threat intelligence to eliminate current uncertainty in the dataset.

H. Sensitivity Analysis

1) Purpose of Sensitivity Analysis: Sensitivity analysis evaluates how changes in uncertain variables—specifically the probability of a successful breach (p)—impact the expected financial outcomes of different authentication strategies. This helps determine robust security thresholds for Cloud IAM, supporting adaptive risk management as attacker sophistication evolves.

2) Expected Value Equations: Let p be the probability of a Breach. The probability of a Stable outcome is (1 - p). Using the payoff values from our decision matrix, the expected value (EV) equations for each alternative are:

- No Control: EV_No_Control = 0(1 - p) + (-248,000)p = -248,000p

$$EV_{NoControl} = -248{,}000p$$

- Monitoring (SIEM): EV_Monitoring = -25,000(1 - p) + (-173,800)p = -25,000 - 148,800p

$$EV_{Monitoring} = -25{,}000 - 148{,}800p$$

- FIDO2 (Physical Keys): EV_FIDO2 = -50,000(1 - p) + (-62,400)p = -50,000 - 12,400p

$$EV_{FIDO2} = -50{,}000 - 12{,}400p$$

3) Critical Probability Thresholds: To determine which decision is optimal at different risk levels (p), we solve for the intersection points where the EV of one alternative equals another:

- No Control vs. FIDO2:

$$\begin{aligned} -248{,}000p &= -50{,}000 - 12{,}400p \\ 235{,}600p &= 50{,}000 \\ p &= 0.2122 \end{aligned}$$

- Monitoring (SIEM) vs. FIDO2:

$$-25{,}000 - 148{,}800p = -50{,}000 - 12{,}400p$$

$$136{,}400p = 25{,}000$$

$$p = 0.1833$$

Decision Rules:

- p < 0.2122: No Control is the mathematically optimal choice (highest EV).
- p >= 0.2122: FIDO2 (Physical Keys) becomes the optimal choice.

Note: Monitoring (SIEM) is never the optimal strategy under the EV criterion in this specific model, as it is consistently outperformed by either No Control (at low risk levels) or FIDO2 (at high risk levels).

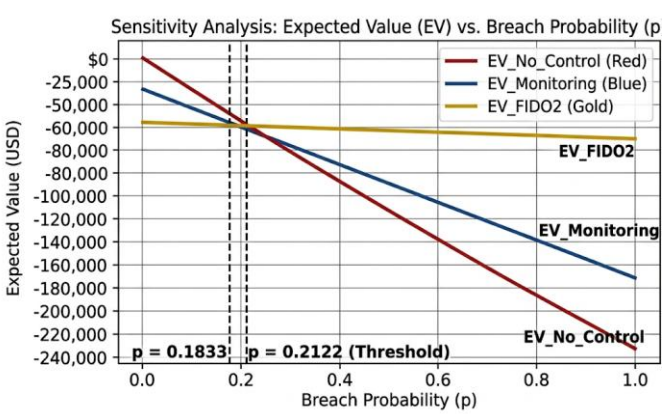

Fig. 6. Sensitivity Analysis Diagram

5) Recommendations and Implications:

- Low Risk (p < 0.2122): Rare successful bypasses -> No Control minimizes upfront costs, making it the statistical favorite for low-threat environments.
- High Risk (p >= 0.2122): Frequent successful bypasses -> FIDO2 (Physical Keys) offers the best financial resilience by capping the impact of breaches.

Strategic Insight:

Our current dataset estimates the probability of breach at p = 0.056 (5.6%), placing the organization in the "No Control" zone. However, the proximity to the 21.22% threshold suggests that as "Adversary-in-the-Middle" (AiTM) kits become more automated and accessible, the optimal strategy will rapidly shift toward FIDO2. For a risk-averse organization, implementing FIDO2 early prevents the $248,000 "Max Loss" scenario identified in the Conservative and Minimax Regret models.

I. Utility Function Assessment

Expected value treats payoffs as linear. In a safety-related system like a Cloud Identity and Access Management (IAM) environment, the decision-maker is often risk-averse. This means avoiding large losses is more important than getting the best average payoff. To represent this behavior, a utility function is used. Let V be the payoff value from the payoff table. A common risk-averse utility function is:

$$U(V) = 1 - \exp(-kV)$$

where $k > 0$ controls the level of risk aversion. In this project, we use $k = 0.00001$ as a reasonable example value. The expected utility of a decision d is:

$$EU(d) = \sum P(s) \times U\big(V(d,s)\big)$$

Using the same outcome probabilities as before:

- Stable (Blocked) = 0.944
- Breach (Successful) = 0.056

And the payoff table:

- D1 (No Control) = [0, -248,000]
- D2 (Monitoring / SIEM) = [-25,000, -173,800]
- D3 (FIDO2 Physical Keys) = [-50,000, -62,400]

First, compute utilities using $k = 0.00005$.

Then compute expected utility:

Table 12: Expected Utility Results ($k = 0.00005$)

Strategy	Expected Utility (EU)
D1 (No Control)	-13,585

Strategy	Expected Utility (EU)
D2 (Monitoring / SIEM)	-336
D3 (FIDO2 Physical Keys)	-11.76

$EU(D1) = 0.944(0.0000) + 0.056(-242{,}582) = 0 - 13{,}585 = -13{,}585$

$EU(D2) = 0.944(-0.284) + 0.056(-5{,}959) = -2.35 - 333.7 = -336.1$

$EU(D3) = 0.944(-11.182) + 0.056(-21.66) = -10.55 - 1.21 = -11.76$

Interpretation:

Increasing risk aversion changes the decision outcome by heavily penalizing catastrophic losses. Although No Control has no upfront cost, its large breach impact results in poor utility performance. Monitoring (SIEM) reduces risk but still allows significant losses. FIDO2 Physical Keys (D3) limit breach consequences and achieve the highest expected utility. Therefore, under risk-averse decision-making, FIDO2 is the preferred strategy for protecting the Cloud IAM system.

VI. DISCUSSION

The analysis confirms that while legacy MFA provides baseline protection, it fails against automated bypasses. The Poisson Distribution shows a 79.81% annual breach likelihood, yet the low current frequency (p = 0.056) causes Expected Value (EV) to favor "No Control" due to high upfront costs. However, Sensitivity Analysis reveals a critical 21.22% threshold; beyond this, FIDO2 becomes the only mathematically sound choice. By neutralizing the Token Theft (24%) and AiTM (12%) paths identified in the Fault Tree, FIDO2 compounds system resilience, dropping total failure probability from 5.6% to 0.28%. This hedge protects the organization from the $248,000 catastrophic loss identified in the F-N Curve, capping exposure at $62,400.

VII. CONCLUSION

Traditional MFA is insufficient against modern session-interception threats. Quantitative modeling through Bayesian Networks and Minimax Regret proves that FIDO2 (Phishing-Resistant MFA) is the superior strategic choice. It reduces bypass success from 79% to 5% and provides a stable financial "floor" that linear EV models overlook.

Immediate investment in FIDO2 hardware is recommended as a vital financial and technical hedge, ensuring long-term resilience within the Cloud IAM ecosystem.

REFERENCES:

[1] Akamai, "Risk Assessment of Multi-Factor Authentication (MFA) Security," Akamai Technologies, White Paper, 2024.

[2] C. Cimpanu, "FBI warns about attacks that bypass multi-factor authentication (MFA)," *ZDNET*, Oct. 2025.

[3] New York Department of Financial Services (DFS), "Report on Investigation into the July 2020 Twitter Incident," DFS Report, 2020.

[4] C. Cimpanu, "Chinese hacker group caught bypassing 2FA," *ZDNET*, Dec. 2019.

[5] O. Minks, "Token Theft Attacks & MFA Defeat: 2025 State of Infosec," *FRSecure Blog*, Jun. 2025. [Online]. Available: https://frsecure.com/blog/token-theft-attacks-mfa-defeat/

[6] L. A. Meyer *et al.*, "How effective is multifactor authentication at deterring cyberattacks?," *Microsoft AI for Good Lab*, Tech. Rep. arXiv:2305.00945, 2023.

[7] IBM Security, "Cost of a Data Breach Report 2023," IBM Corporation, Tech. Rep., 2023.

[8] Yubico, "YubiKey 5 Series Pricing," *Yubico Official Store*, 2024. [Online]. Available: https://www.yubico.com/store/

[9] Progressive Commercial, "Average Cost of Cyber Insurance 2024," *Progressive Casualty Insurance Company*, 2024. [Online]. Available: https://www.progressivecommercial.com/business-insurance/cyber-insurance-cost/

[10] S. Agarwal *et al.*, "Risk Analysis of Establishing 5G Infrastructure in Tsunami-Prone Areas," Concordia University, Course Project Report, 2026.